# CIVICCONNECT

## Project Engineering Document (PED) v4.0 Final


### Abstract

Milestone 4 — Finalise, Consolidate & Conclude



Runtime Terrors

Tsholofelo Lephondo - 602745

Nhlavutelo Shiviri - 602944

Rethabile Ledidi -601910

| | |
|---|---|
| **Team** | Runtime Terrors — Nhlavutelo Shiviri (602944), Frontend · Tsholofelo Lephondo (602745), Backend · Rethabile Ledidi (601910), Database |
| **GitHub repository** | https://github.com/rethabileledidi/CivicConnect_Runtime-Terrors |
| **Final release baseline** | Tag v1.0-final on main |
| **PED version** | v4.0 Final (continues PED v1.0, v2.0 and v3.0) |
| **Final deployment state** | Simulated staging — evidence-based no-go (Section 4) |
| **Referencing** | Harvard |
| **Date submitted** | 18 October 2026 |

# Contents

0. Submission information and document control

1. Final product and release baseline

2. M1 scope → final delivery

3. Final acceptance evidence and M3 closure

4. Final deployment state: staging, no-go

5. Final RTM and project registers

6. Project reflection and conclusion

References

*PED v4.0 continues PED v3.0. Content that did not change in M4 (stakeholders, architecture, API, data and UI design, M3 test design) remains in PED v1.0–v3.0 and is referenced, not repeated.*

PED v4.0 closes the CivicConnect project. It continues PED v3.0 (M3) without recreating it: Sections 1–10 of v3.0, the architecture, API and data design in v2.0, and the M1 baseline in v1.0 stay valid and are referenced, not repeated. This version records the M4 finalisation (FR-09, FR-12, security fixes and usability evidence), the final baseline, the M1 scope reconciliation, final register status and the go-live decision (SEN381, 2026c).

# 0. Submission information and document control

| Item | Detail |
|---|---|
| Team | Runtime Terrors — Nhlavutelo Shiviri (602944), Frontend · Tsholofelo Lephondo (602745), Backend · Rethabile Ledidi (601910), Database |
| GitHub repository | https://github.com/rethabileledidi/CivicConnect_Runtime-Terrors |
| Final release baseline | Tag `v1.0-final` on `main`, after PR `m4-finalise`, the acceptance-evidence PR and the PED v4.0 PR are merged. Commit hash: [enter on submission] |
| PED version | v4.0 Final (continues v1.0, v2.0, v3.0) |
| Final RTM location | Section 5.1 of this PED (continues PED v3.0 Appendix A.1) |
| Acceptance evidence | `docs/quality/m4-acceptance-checks.md` (EV-01, EV-02) |
| Final product access | Live demonstration on simulated staging built from `v1.0-final`; run steps in `RUNNING.md` (migrations V0–V8) |
| Final deployment state | Staging — evidence-based no-go (Section 4) |
| Date submitted | 18 October 2026 |

| Version | Date | Summary | Status |
|---|---|---|---|
| 4.0 | 2026-10-18 | FR-09 and FR-12 delivered (V8, ADR-P2-04, TC-24–26); TanStack Start XSS patched; app role restored for Tomcat; NFR-04/07 evidenced; branch protection enabled; M1 scope → delivery (95.0%); no-go decision; registers concluded | Final |
| 3.0 | 2026-10-11 | M3 evidence index; CR-06 to CR-10; tests, CI, PT-01, restore | Baselined |
| 2.0 | 2026-09-30 | Architecture, stack, data model, ADRs, API, security | Baselined |
| 1.0 | 2026-09-09 | Problem, stakeholders, scope, requirements, RTM, risks | Baselined |

# 1. Final product and release baseline

The final product is the M3 release candidate (`52c57cc`) plus controlled finalisation: the two Must items CR-08 carried forward, one security patch, one configuration correction and the usability evidence. The architecture, stack and existing behaviour did not change, and the whole product was retested on the team laptop after the change.

## 1.1 What changed between the M3 release candidate and the final version

| Change | What it does | Item closed | Evidence |
|---|---|---|---|
| V7 hotfix (PR #5, merged 18 Oct) | Pins search_path on the three V1 trigger functions in databases built before ac5de97, so new requests cannot fail on staging; idempotent | DF-01 (existing databases) | CI migration step V1–V8; reapplied safely on a database already at V8 |
| `feat(db)` V8 | `request_category.is_restricted` and a *Safety or Security Concern* category; append-only `request_comment`; length CHECKs on description, resolution notes and history notes | FR-09, FR-12 (data); TD-02, DF-02 | TC-26; CI migration step V1–V8 |
| `feat(backend)` | `AccessPolicy`: coordinators denied restricted requests (404) and they are left out of the queue, JSP report lists and CSV export; POST `/api/requests/{id}/comments`; comments returned only to staff and oversight | FR-09, FR-12, RR-03, R-19 | TC-24, TC-25; ADR-P2-04 |
| `feat(frontend)` | Comments panel in the work queue; confidentiality hint when a resident picks a restricted category | FR-09 (UI), NFR-04 support | E2E-3; EV-01 |
| `fix(deps)` | TanStack Start 1.168.32 → 1.168.60 (with react-router 1.170.41, router-plugin 1.168.42): patches a critical reflected XSS | DF-05 | `npm audit --omit=dev` clean; type-check and build pass |
| Tomcat configuration (not in the repository) | Removed a `setenv` override that started the app as the `postgres` superuser; Tomcat now connects as `civic_app` | DF-06 | Health UP; `civic_app` DELETE refused |
| `docs(quality)` | Viewport check and first-time-user walkthrough, run and recorded by N. Shiviri | NFR-04, NFR-07 | EV-01, EV-02 |

V8 is additive, so the M3 build still runs on the new schema and rollback stays “redeploy the previous WAR”. No feature outside the approved scope was added.

### 1.2 Critical user journeys in the final version

All three were run end to end on the final build on 18 October and behaved as specified.

1. **E2E-1 (TC-22)** — resident signs in, reports a water leak, sees the reference number and status *Submitted* on *My requests*.
2. **E2E-2 (TC-23)** — coordinator assigns, staff starts and resolves with notes, resident closes and rates; each role sees only its permitted buttons; five attributed history rows are written.
3. **E2E-3 (new)** — resident reports a *Safety or Security Concern* and sees the confidentiality hint; the coordinator cannot see it in the queue or by URL; the manager assigns it; staff add a comment the resident cannot see.

## 2. M1 scope → final delivery

Final Scope Completion is **95.0%** (19.0 of 20 acceptance criteria). **Every functional requirement (FR-01–13) is met**, and the only shortfalls are two Must quality criteria that can only be proven on a real host. All 20 criteria baselined in PED v1.0 are counted; no approved change removed any of them, so the denominator is unchanged.

### 2.1 Reconciliation table

Met = 1.0, Partially met = 0.5, Not met = 0.0. Evidence IDs refer to PED v3.0 Section 7, Section 3 and Section 5.1 below.

| Req | M1 priority | Final status | Acceptance criterion | Value | Evidence | Conclusion / reason for variance |
|---|---|---|---|---|---|---|
| FR-01 Submit request | Must | Implemented | Met | 1.0 | TC-08, 17, 22 | Delivered as committed |
| FR-02 Confirm receipt | Must | Implemented | Met | 1.0 | TC-22; PT-01 | Reference shown on confirmation |
| FR-03 View status | Must | Implemented | Met | 1.0 | TC-05, 22 | Delivered as committed |
| FR-04 Request history | Should | Implemented | Met | 1.0 | TC-05, 22 | Only own requests listed |
| FR-05 Search / filter / sort | Must | Implemented | Met | 1.0 | TC-14, 15, 21 | Delivered as committed |
| FR-06 Full detail + history | Must | Implemented | Met | 1.0 | TC-17, 23 | Delivered as committed |
| FR-07 Assign | Must | Implemented | Met | 1.0 | TC-02, 20, 23 | Delivered as committed |
| FR-08 Controlled transitions | Must | Implemented | Met | 1.0 | TC-01, 04, 06, 17–19, 23 | Strongest evidence (3 levels) |
| FR-09 Comments | Must | Implemented in M4 | Met | 1.0 | TC-24, 26; E2E-3 | Timestamped by the database, attributed, refused on edit or delete |
| FR-10 Resolve / close | Must | Implemented | Met | 1.0 | TC-03, 23 | Resolution notes required |
| FR-11 Management summary | Must | Implemented | Met | 1.0 | TC-16, 21 | Counts equal records |
| FR-12 Restrict sensitive requests | Must | Implemented in M4 | Met | 1.0 | TC-25, 26; E2E-3 | Coordinators denied restricted requests (404) and they are left out of lists |
| FR-13 Status notification | Should | Implemented | Met | 1.0 | TC-07, 12, 13, 23 | In-app plus simulated SMS/WhatsApp |
| NFR-01 Confirmation time | Must | Partially implemented | Partially met | 0.5 | PT-01 | Submit p95 44 ms at database tier; full browser → Tomcat round trip never measured |
| NFR-02 Authentication / RBAC | Must | Implemented | Met | 1.0 | TC-05, 09–11, 25 | Other users’ requests return 404; app runs as least-privilege `civic_app` (DF-06) |
| NFR-03 Immutable history | Must | Implemented | Met | 1.0 | TC-17, 19, 26 | Append-only triggers on history and comments |

| Req | M1 priority | Final status | Acceptance criterion | Value | Evidence | Conclusion / reason for variance |
|---|---|---|---|---|---|---|
| NFR-04 Usable without training | Should | Implemented | Met | 1.0 | EV-02 | A first-time user completed a submission without any explanation |
| NFR-05 Within free-tier limits | Must | Partially implemented | Partially met | 0.5 | PED v3.0 §11.4 | ≈73 MB/year estimated, 16 MB per 10,000 requests measured; no host chosen, so no quota to test against (D-08) |
| NFR-06 Consistent rules | Must | Implemented | Met | 1.0 | TC-01, 04 | Same rejection from every role and path |
| NFR-07 Desktop and mobile | Should | Implemented | Met | 1.0 | EV-01 | All six core flows passed at 375 px and 1280 px |
| **Total** | | | | **19.0 / 20** | | **95.0%** |

Out-of-scope items (native apps, channel ingestion, multi-tenancy, AI routing, public API, payments) remained out of scope and are not counted. Deferred items behaved as planned, with one exception: simulated SMS/WhatsApp was built although M1 deferred outbound channels. It was added during M2 construction and costs nothing because messages are only written to the outbox, never sent.

### 2.2 Calculation

**Scope Completion = (18 × 1.0 + 2 × 0.5 + 0 × 0.0) ÷ 20 × 100 = 19.0 ÷ 20 × 100 = 95.0%**

The percentage is not inflated by trivial items: all thirteen functional requirements are fully met, including every Must. The two partial criteria are performance and cost targets that depend on the hosting decision the no-go deliberately left open (Section 4).

### 2.3 Remaining Must-criterion variances and CR-11

| Item | Why not complete | Consequence for stakeholders |
|---|---|---|
| NFR-01 full-stack timing | No host and no HTTP-level timing harness (TD-06) | Target very likely met (2% of budget at the database) but unproven end to end |
| NFR-05 free-tier fit | Hosting decision D-08 left open by the no-go (Section 4) | Cost risk low on the measured data size, but unverified |

**CR-11 (18 Oct 2026).** Requested by the team. Change: (1) deliver FR-09 and FR-12 in M4 as CR-08 planned, through one reviewed PR; (2) carry TD-06 (HTTP-level tests) and TD-07 (HTTPS and `Secure` cookie) into future work. Impact: two Must criteria move to Met; RR-03 closes; TD-07 keeps production blocked (Section 4). Decision: accepted. The baseline and denominator are unchanged; TD-06 and TD-07 stay visible as open debt.

## 3. Final acceptance evidence and M3 closure

The final build passes **85 of 85 automated tests** (64 unit/component, 21 database) with none skipped, rerun with `mvn verify` against PostgreSQL 16 on the team laptop on 18 October after all final changes. The 17 new tests cover only the M4 change; M4 sets no test-count target (SEN381, 2026c).

### 3.1 New verification for the M4 change

| ID | Evidence | Level | Technique | Result | Req. |
|---|---|---|---|---|---|
| TC-24 | `CommentsAndRestrictedAccessTest` (5 comment tests) | Component | Decision table; BVA 0/1/1000/1001 characters | Pass: assignee and oversight may comment; residents get 403 and never see comments; other staff get 404; invalid lengths store nothing | FR-09 |
| TC-25 | `CommentsAndRestrictedAccessTest` (5 access tests) | Component | Decision table; negative | Pass: coordinator gets 404 and an empty queue for restricted requests; requester, assignee and manager still see them; manager can assign | FR-12, NFR-02 |
| TC-26 | `CommentsAndRestrictedAccessDbTest` (7 tests) | Integration (DB) | Negative; integration | Pass: comments ordered and attributed; UPDATE and DELETE refused; blank and 1,001-character rejected; queue and reports leave restricted rows out; description > 2,000 refused | FR-09, FR-12, TD-02 |

| ID | Evidence | Level | Technique | Result | Req. |
|---|---|---|---|---|---|
| E2E-3 | Live run, 18 Oct | System | Acceptance; decision table | Pass: as described in Section 1.2 | FR-09, FR-12 |
| EV-01 | `docs/quality/m4-acceptance-checks.md` | System | Viewport check, 375 × 812 and 1280 × 800 | Pass: six core flows, no sideways scroll or unusable control | NFR-07 |
| EV-02 | `docs/quality/m4-acceptance-checks.md` | System | First-time-user walkthrough, think-aloud | Pass: submission completed with no explanation | NFR-04 |

TC-25 and TC-26 were checked against a deliberate regression (coordinator rule reverted): both failed as expected, then passed when restored. The least-privilege role `civic_app` can insert comments but gets *permission denied* on DELETE, both in a test database and on the running system after DF-06 was fixed.

**Confirmation run.** Pushing `v1.0-final` triggers CI and CodeQL on the final commit. Before submission, replace this sentence with the two run numbers (CI run [number], CodeQL run [number]).

**Why a working screen is not acceptance.** A screen shows one path with one user. FR-12 is accepted because the coordinator rule is tested in the service (TC-25) and in the SQL the queue and reports run (TC-26); E2E-3 only illustrates it.

### 3.2 Defects and M3 issues — final status

| ID | Item | Final status | Evidence / consequence |
|---|---|---|---|
| DF-01 | Trigger `search_path` broke DB tests (M3) | Fixed and reverified | `ac5de97`; CI green since #4; V8's new trigger pins `search_path` the same way |
| DF-02 | No DB length cap on long text (M3) | Fixed | V8 CHECKs; TC-26 |
| DF-03 | Boundaries tested on one side only (M3) | Partly fixed | New comment rules tested on both edges (TC-24); the M3 edges (title, password, rating) remain one-sided |
| DF-04 | Health endpoint lacks build version (M3) | Open → TD-04 | Release identified by tag and `git log -1` in the demo |
| DF-05 | `npm audit` (18 Oct): critical reflected XSS in TanStack Start server-function responses, GHSA-qx66-fv34-fjm8 (Netlify, 2026) | Fixed | Upgraded to 1.168.60; `npm audit --omit=dev` reports 0 critical; type-check and build pass. Found by a manual check because the dependency-review gate from PR #4 is not running (see PR #4 below) |
| DF-06 | Tomcat `setenv` passed the `postgres` superuser login (and its password, printed in the startup log) to the app | Fixed | Override removed; app connects as `civic_app`; DELETE refused for the running app; superuser password rotated and old logs deleted |
| PROC-01 | Merge on red; direct commits to `main` (M3) | Partly closed | Branch protection on `main`, set by the repository owner, now blocks direct pushes and merges without green checks, and requires **one** approval. The brief's second approval (Master Brief §9) is still a team agreement, not enforced by GitHub |
| PR #4 | Dependency review and ESLint gate | Merged 18 Oct, but not active | Its workflow was committed as ci.yml at the repository root, where GitHub Actions does not run it, so dependency review and ESLint are still not running. DF-05 shows their value; moving the file into .github/workflows/ is the first item of future work |
| RR-01 | Full-stack load untested | Retained | No host chosen to re-test on |
| RR-02 | HTTP only, single host | Retained — blocks go-live | Section 4 |
| RR-03 | Sensitive requests visible to coordinators | Closed | FR-12 delivered; TC-25, TC-26 |
| RR-04 | Single PostgreSQL instance | Mitigated for staging | pg_dump restore verified 11 Oct; no managed backups |

**DEV-04 (18 Oct).** PED v3.0 (`b9bb6d9`) was committed directly to `main` before the M4 work started. It is the last recorded deviation: branch protection now makes direct commits impossible, and all M4 work entered through reviewed pull requests.

## 4. Final deployment state: staging, no-go

CivicConnect remains on simulated staging (PED v3.0 §8.2, ADR-13). The application is functionally complete and verified, but it has no encrypted transport and no scheduled backups, so releasing it to residents would expose their passwords, session cookies and personal data and risk losing their records. The team does not approve go-live.

### 4.1 Blocking and resolved concerns

| Concern | Affected requirement / risk | Likely consequence if released | Status / what must happen before go-live |
|---|---|---|---|
| **Blocking:** no HTTPS; session cookie lacks the `Secure` flag | NFR-02, RR-02, TD-07 | Session cookies and passwords readable on any shared network; OWASP lists this under cryptographic failures and misconfiguration (OWASP, 2025; MDN, 2026) | TLS at the host; `Secure` cookie; HSTS |
| **Blocking:** single database, manual backup only | RR-04 | Residents' records lost back to the last manual dump | Scheduled, tested backups on the host |
| Full-stack performance unmeasured | NFR-01, RR-01 | Probably acceptable, unproven on a real host | Re-run PT-01 through HTTP on the chosen host |
| Sensitive requests visible to coordinators | FR-12, RR-03 | Over-disclosure of security reports | Resolved in M4 (TC-25, TC-26) |
| Unreviewed or failing changes reaching `main` | RR-06, PROC-01 | Untested code in front of users (happened once, DEV-01) | Mostly resolved: branch protection blocks direct pushes and requires green checks and one approval (GitHub, 2026c); the second approval relies on team agreement. Raise the rule to two approvals before go-live |
| Critical XSS in a frontend dependency | DF-05 | Script injection from the app's own origin | Resolved: TanStack Start 1.168.60 |
| App connected as database superuser | DF-06, NFR-02 | Least privilege bypassed; any SQL possible | Resolved: Tomcat uses `civic_app` |

### 4.2 Why this is a defensible no-go

The blockers are security and operations controls, not unfinished work: every functional requirement is met, the security defects found during M4 were fixed and verified, and governance is now enforced by GitHub. The remaining gap is the transport and backup layer that only a real host can provide. Releasing a system holding names, phone numbers and security reports over plain HTTP would be unsafe whatever the deadline.

What is ready: the release is identified by tag, passes 85/85 automated tests, runs as a least-privilege database role, restores from backup, and rolls back by redeploying the previous WAR because V8 is additive. Promoting it needs the two blocking items and a host decision (D-08), not a redesign.

### 4.3 Release classification

PED v3.0 rated the candidate **CONDITIONALLY READY**, with three conditions: FR-12, enforced governance and E2E success. All three are now met. The final classification is **READY AS A STAGING DEMONSTRATOR; NOT READY FOR PRODUCTION** until HTTPS and scheduled backups exist.

## 5. Final RTM and project registers

The RTM and registers below continue PED v3.0 Appendix A; unchanged rows are summarised, not recreated. All implementation and evidence references point to `v1.0-final`.

### 5.1 Final RTM v4.0

| Req | Stakeholder need | Decision / design | Final implementation | Final evidence | Open item | Final outcome |
|---|---|---|---|---|---|---|
| FR-01/02 | Requester: low-friction submission, proof of receipt | ADR-01 REST; stored `reference_no` | `RequestService.submit` | TC-08, 17, 22; PT-01 | — | Met |
| FR-03/04 | Requester: visibility of own requests | ADR-P2-02 session auth; `AccessPolicy` | `scope=mine` | TC-05, 22 | — | Met |
| FR-05 | Staff: prioritise, avoid duplicates | Indexes follow reads (§11.4 v3.0) | `RequestQueryBuilder` | TC-14, 15, 21 | TD-08 | Met |
| FR-06/07 | Staff: full detail, single owner | CHECK assignee rule | `RequestService.detail`; `RequestStates` | TC-02, 17, 20, 23 | — | Met |
| FR-08, NFR-03/06 | Management: auditable trail | ADR-04 State; ADR-05 same-transaction audit; deferred trigger | `lifecycle/*`; V1 triggers | TC-01, 04, 06, 17–19, 23 | DF-03 (partly) | Met |

| Req | Stakeholder need | Decision / design | Final implementation | Final evidence | Open item | Final outcome |
|---|---|---|---|---|---|---|
| FR-09 | Staff: record actions | ADR-P2-04: separate append-only table; internal to staff | V8 `request_comment`; `RequestService.addComment`; POST `…/comments`; staff page panel | TC-24, 26; E2E-3 | — | Met |
| FR-10 | Staff: resolve/close | Resolution notes required | Validator + CHECK | TC-03, 23 | — | Met |
| FR-11 | Management: reporting | ADR-P3-03 views | Reporting views; CSV writer | TC-16, 21 | Dashboard counts include restricted requests (no content shown) | Met |
| FR-12, NFR-02 | Security: sensitive data | ADR-P2-04: restriction per category; 404 on denial; least-privilege app role | V8 `is_restricted`; `AccessPolicy.canView`; queue SQL; `RequestQueryBuilder`; JSP detail; Tomcat as `civic_app` | TC-02, 05, 09–11, 25, 26; E2E-3; DF-06 check | — | Met |
| FR-13 | Requester: feedback | ADR-05 observer + outbox | `notification/*` | TC-07, 12, 13, 23 | — | Met |
| NFR-01 | Fast confirmation | One call per action | — | PT-01 (DB tier only) | RR-01, TD-06 | Partially met |
| NFR-04 | Usable without training | Short form, field hints, confidentiality note | `report.tsx` | EV-02 | — | Met |
| NFR-07 | Usable on any device | Tailwind responsive UI | Frontend routes | EV-01 | — | Met |
| NFR-05 | Low cost | Free stack; D-08 hosting | — | Capacity estimate + PT-01 size | D-08 open | Partially met |

## 5.2 Risk Register — closing status

| ID | Risk | Final status |
|---|---|---|
| R-02 | Schedule overrun | Materialised in M3 (FR-09/12 slipped); recovered in M4 by one scoped PR |
| R-03 | Scope creep | Controlled; simulated SMS/WhatsApp was the only addition |
| R-04 | Security as an afterthought | Mitigated; M4 found and fixed DF-05 and DF-06; residual RR-02 (HTTPS) blocks release |
| R-08 | Oracle JDK licence | Closed for CI and staging builds (Temurin); one developer laptop uses Oracle JDK 21.0.10, released before the October 2026 licence change |
| R-18 | Integration regressions | Mitigated; 85 tests in CI and rerun locally |
| R-19 | FR-12 flag missing | Closed (V8, TC-25, TC-26) |
| R-20 | Changes bypass review | Materialised four times (DEV-01–04); reduced by branch protection (direct pushes blocked, one approval required) → RR-06 partly closed |
| R-22 | Performance missed on real host | Open; untestable without a host |
| R-23 (new) | Vulnerable third-party dependency ships unnoticed | Materialised (DF-05); fixed; mitigation is activating PR #4's dependency review by moving its workflow into .github/workflows/ |

## 5.3 Technical Debt Register — closing status

| ID | Debt | Final status | Maintenance consequence |
|---|---|---|---|
| TD-01 | FR-09 / FR-12 not built | Repaid (PR `m4-finalise`) | — |
| TD-02 | No DB length cap on long text | Repaid (V8 CHECKs) | — |
| TD-03 | `reference_no` collides after 999,999 | Retained | None at ~18,250 a year for 50 years |
| TD-04 | Health endpoint lacks version | Retained | Release identity relies on the git tag |
| TD-06 | No HTTP-level API tests | Retained (CR-11) | Servlet and filter changes, including the new comments route, are untested at the wire |
| TD-07 | `Secure` cookie off | Retained (CR-11) — release blocker | Must be fixed with HTTPS |
| TD-08 | Open-queue query scans all rows | Retained | Query time grows with history; fine at measured scale |
| TD-09 (new) | Restricted rule enforced in two code paths (API, JSP reports) | Accepted (ADR-P2-04) | Any new list screen must reuse `AccessPolicy` or `RequestQueryBuilder` |
| TD-10 (new) | 10 pre-existing TypeScript strict-mode errors in 6 frontend files; CI's frontend `build` (`vite build`) does not type-check | Retained | Frontend type mistakes are not caught by CI; add `tsc --noEmit` to the job and fix the 10 errors |

### 5.4 Decisions — closing status

| ID | Decision | Final status |
|---|---|---|
| ADR-P2-04 | Restricted categories; append-only internal comments | Accepted (M4) |
| D-08 | Production hosting | Closed: not selected; no-go (Section 4) |
| D-10 | Upgrade to Java 25 | Closed: rejected for the final release; Java 21 LTS is supported to 2028 |
| D-12 | FR-12 restricted flag | Closed: delivered per category (ADR-P2-04) |
| D-17 | Team-agreement gates | Partly closed: GitHub enforces checks and one approval; the second approval stays a team agreement |
| CR-11 | Deliver FR-09/FR-12; carry TD-06, TD-07 | Accepted 18 Oct 2026 (Section 2.3) |

### 5.5 AI Usage Register — M4 entries

| Date | Member | Tool | Task | Verification | Issues found |
|---|---|---|---|---|---|
| 2026-10-18 | T. Lephondo | Claude | Drafted V8, the FR-09/FR-12 backend and frontend changes, TC-24–26 and ADR-P2-04; drafted PED v4.0; guided the dependency upgrade and the Tomcat fix | 85/85 tests rerun on the team laptop; migrations replayed with `ON_ERROR_STOP`; deliberate regression made the new tests fail; `civic_app` grants checked on the running system; `tsc --noEmit` and `npm audit`; schema reviewed by R. Ledidi and UI by N. Shiviri in the PR; CI on the PR | One type error in the new comments panel (fixed before commit); an unused method and an over-optimistic release label (removed). AI-drafted text was checked against the repository and test output |

## 6. Project reflection and conclusion

CivicConnect delivers the M1 problem — one controlled, auditable and access-controlled lifecycle per request — with every functional requirement met, 95% of the baselined criteria complete and all three critical journeys working; it is held back from production only by transport security and backups.

| Area | Evidence-based conclusion |
|---|---|
| Problem and value | Requesters get a reference and live status; staff get one queue with ownership and working notes; management gets counts that match records (TC-21); security reports reach only authorised people (TC-25); a first-time user can report a problem unaided (EV-02). The fragmented-channel problem from M1 is addressed for every role |
| Scope | 95.0%; 18 criteria fully met. The two partial criteria (full-stack timing, free-tier fit) need a host |
| Quality | Highest confidence in the lifecycle, audit and access rules: each enforced in the service and the database, 85 tests, rerun after the final changes. Least confidence in the HTTP layer (no wire-level tests) and the frontend's type safety (TD-10) |
| Risk, defects, debt | DF-01, DF-02, DF-05 and DF-06 fixed; RR-03 closed and RR-06 reduced. Two release blockers (HTTPS, backups) and seven debt items remain, all recorded |
| Execution | Most M2/M3 code arrived in one large push on 30 Sep, FR-09/FR-12 slipped from M3, and unenforced review let a red build merge once. M4 recovered with one scoped, reviewed PR, two security fixes found by checking rather than assuming, and enforced branch protection |
| Future | 1) HTTPS + `Secure` cookie + HSTS on a chosen host; 2) scheduled backups; 3) activate PR #4's dependency review and ESLint and add `tsc --noEmit` to CI (R-23, TD-10); 4) HTTP-level tests (TD-06); 5) re-run PT-01 on the host; then repeat the go-live decision |

### 6.1 Decision consequences

| Decision (evidence at the time) | Actual outcome | Would we decide again? |
|---|---|---|
| **ADR-05 / deferred trigger** — audit row in the same transaction, enforced by PostgreSQL at commit (M2: NFR-03 is Must) | Positive. Made FR-08/NFR-03 the best-evidenced requirement, survived a backup–restore, and gave M4 a ready pattern for append-only comments. Cost: the trigger caused DF-01, the only high-severity M3 defect | Yes — the defect was a configuration error, not a design flaw |
| **ADR-01 layered monolith + `AccessPolicy` in one place** | Positive. FR-12 changed one policy class, one SQL clause and two report paths; the 404 rule from M3 handled denial with no new error type. Cost: the JSP reports needed their own check (TD-09) | Yes; a single query service for both UIs would remove TD-09 |
| **CR-10 / team-agreement governance** — accepted because only the owner could enable protection | Negative until M4. The agreed gate was bypassed four times, including a merge on red CI. Enabling protection took minutes | No — the owner should have enabled branch protection in M1; it had the largest process consequence in the project |
| **Frontend scaffold (Lovable / TanStack Start, M2)** — fastest way to a working UI | Mixed. It delivered the UI quickly but brought a server runtime the product does not need, a critical dependency advisory (DF-05) and a strict type configuration nobody enforced (TD-10) | Partly — keep the components, but choose a plain client-side Vite + React setup and check `npm audit` from the start |

### 6.2 Conclusion

The project shows that a three-person team can engineer a small system whose central rules — legal transitions, an unalterable audit trail and restricted access to sensitive reports — are each enforced in two layers and traceable from the M1 stakeholder conflicts to tests and live evidence. It also shows the cost of late integration and unenforced process: Must items slipped a milestone, and two security defects were found only when the final build was checked carefully. The honest final decision is to keep the product on staging until it can be served securely and backed up.

## References

References in PED v3.0 remain in force for the evidence it holds. All sources are dated 2023 or later.

GitHub (2026c) *About protected branches*. GitHub Docs. Available at: https://docs.github.com/en/repositories/configuring-branches-and-merges-in-your-repository/managing-protected-branches/about-protected-branches (Accessed: 18 October 2026).

Lephondo, T., Shiviri, N. and Ledidi, R. (2026) *CivicConnect Project Engineering Document v3.0*. Unpublished team submission, Belgium Campus ITversity.

MDN (2026) *Set-Cookie header*. MDN Web Docs, Mozilla. Available at: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Set-Cookie (Accessed: 18 October 2026).

Netlify (2026) *TanStack Start XSS vulnerability: what Netlify users need to know*. Netlify Changelog, 30 September. Available at: https://www.netlify.com/changelog/2026-09-30-tanstack-start-security-vulnerability/ (Accessed: 18 October 2026).

OWASP (2025) *OWASP Top 10:2025*. OWASP Foundation. Available at: https://owasp.org/Top10/2025/0x00_2025-Introduction (Accessed: 18 October 2026).

SEN381 (2026a) *CivicConnect Master Project Brief*, v1.1. Software Engineering 381, Belgium Campus ITversity.

SEN381 (2026c) *CivicConnect Final Project / Milestone 4: finalise, consolidate and conclude*. Software Engineering 381, Belgium Campus ITversity.